UNIVERSITI TEKNOLOGI MARA
MARKING SCHEME

COURSE	:	COMPUTER SECURITY
COURSE CODE	:	CSC662
EXAMINATION	:	OCTOBER 2026 (MOCK)
TIME	:	3 HOURS

MARKING SCHEME NOTES

1. This marking scheme accompanies the CSC662 mock paper (October 2026). Computed answers show working; theory answers are supported by lecture slides (not lecturer-marked) with a verbatim quote and slide citation.

2. Supported theory marking points quote the lecture decks; any unresolved slot would remain a visible placeholder.

3. Part A = 10 x (2 + 6); Part B = 2 x (5 + 5); total = 100 marks.

4. Computed: 2 slot(s). Supported theory: 22 slots. Placeholders: 0. Questions and answers are for local study use only.

5. Near-copy rejection used all 35 past papers; style widening is recorded per slot.

FOR MARKERS' USE ONLY

This marking scheme consists of 14 printed pages

© Hak Cipta Universiti Teknologi MARA

CSC662 - MARKING SCHEME (MOCK OCTOBER 2026)

Labels: computed / supported by lecture slides (not lecturer-marked) / placeholder. No official marking scheme exists for the real CSC662 papers; this is generated for the mock.

Entailment labels: supported = the quote directly supports the marking point (or the point passed the stem-overlap gate without an LLM check); partly supported = the quote supports part of the point or is ambiguous; not supported = the quote does not support the point. Only 'not supported' points triggered regeneration.

Part A: 10 x (2 + 6) = 80 marks. Part B: 2 x (5 + 5) = 20 marks. Total: 100 marks. Slots: 2 computed, 22 supported by lecture slides, 0 placeholder.

Methods: computed answers use verified solvers. Theory answers are supported by lecture slides (not lecturer-marked). Each marking point carries a verbatim quote, a deck/slide/chunk citation and a term-overlap score; low overlap is flagged for human review. Sources are restricted to the slot topic's allowed decks, and a slide is not reused across questions where an alternative exists.

PART A - QUESTION 1

A1a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State two reasons why software insecurity arises, according to the lecture.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	Attackers can cause insecurity by modifying system resources that are critical to program execution, such as the instruction pointer or function call addresses.	"Software insecurity stems from attacker's ability to modify system resources criticial for program execution, e.g. instruction pointer, function call addresses, interrupt addresses, etc."	051 - Software Security, slide 30 051 - Software Security::s30::1	supported (stem gate)	0.75
2	A key source of software insecurity is the failure to properly validate user input.	"One of the key sources for software insecurity is failed validation of user input."	051 - Software Security, slide 30 051 - Software Security::s30::1	supported (stem gate)	0.75

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 051 - Software Security, slide 30

A1b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain three Windows security mechanisms or components described in the lecture and, for each, one security concern that arises from it.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	Windows provides complex mechanisms for managing user accounts, objects and access control.	"Windows systems contain complex security mechanisms for user account and object management as well as access control."	041 - Windows Security, slide 21 041 - Windows Security::s21::1	supported (stem gate)	0.90
2	Discretionary access control (DACS) allows fine-grained control over diverse entities in Windows and its applications.	"DACS enable fine-grained access control of heterogeneous entities in Windows itself as well as applications."	041 - Windows Security, slide 21 041 - Windows Security::s21::1	supported (stem gate)	0.58
3	The same complexity that gives Windows strong security also makes it vulnerable, since misconfiguration and implementation bugs can cause serious incidents.	"The complexity of Windows security mechanisms is also its enemy: misconfiguration as well as implementation bugs may lead to severe security incidents."	041 - Windows Security, slide 21 041 - Windows Security::s21::1	supported	0.44 LOW

© Hak Cipta Universiti Teknologi MARA

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
4	Active Directory, introduced in Windows 2000, is an LDAP-like directory service used to organize system resources.	"Active directory introduced in Windows 2000 is an LDAP-like directory service for organization of system resources:"	041 - Windows Security, slide 6 041 - Windows Security::s06::1	supported (stem gate)	1.00
5	Active Directory stores security credentials and certificates as part of its directory information.	"Security credentials and certificates"	041 - Windows Security, slide 6 041 - Windows Security::s06::1	partly supported	0.25 LOW
6	Windows subjects are processes and threads, and their security credentials are held in a token that is inherited when new processes are created.	"Security credentials for a subject are stored in a token."	041 - Windows Security, slide 11 041 - Windows Security::s11::1	partly supported	0.33 LOW

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 041 - Windows Security, slide 11; 041 - Windows Security, slide 21; 041 - Windows Security, slide 6

PART A - QUESTION 2

A2a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain how a substitution cipher works and what serves as its key.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	Encryption replaces each plaintext letter with a different letter to produce the ciphertext.	"In substitution ciphers, we replace the plain-text letters with other letters"	031 - Classical Cryptography, slide 4 031 - Classical Cryptography:: s04::1	supported	0.33 LOW
2	The substitution rule itself functions as the key of the cipher.	"The substitution rule is the key"	031 - Classical Cryptography, slide 4 031 - Classical Cryptography:: s04::1	supported	0.40 LOW

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 031 - Classical Cryptography, slide 4

A2b - 6 marks - computed - matches lecture slide 15 (standard tableau)

Question:

Decrypt the following ciphertext using the Vigenere cipher with the key CIPHER. Use the standard 26 x 26 Vigenere tableau, writing the key over the message and repeating it as necessary.
UMRBVVNWVPREQE

Answer: SECURELOGINNOW

The 26 x 26 Vigenere tableau is printed in the question paper.

Working:

```
Standard 26 x 26 tableau, A=0; key repeated over the ciphertext.
Ciphertext: UMRBVVNWVPREQE
Key:        CIPHERCIPHERCI
Letter-by-letter: C - K mod 26 = P
  U (20) - C ( 2) = 18 -> S
  M (12) - I ( 8) =  4 -> E
  R (17) - P (15) =  2 -> C
  B ( 1) - H ( 7) = 20 -> U
  V (21) - E ( 4) = 17 -> R
  V (21) - R (17) =  4 -> E
  N (13) - C ( 2) = 11 -> L
  W (22) - I ( 8) = 14 -> O
  V (21) - P (15) =  6 -> G
  P (15) - H ( 7) =  8 -> I
```

© Hak Cipta Universiti Teknologi MARA

```
  R (17) - E ( 4) = 13 -> N
  E ( 4) - R (17) = 13 -> N
  Q (16) - C ( 2) = 14 -> O
  E ( 4) - I ( 8) = 22 -> W
Plaintext:  SECURELOGINNOW
```

Suggested marks: 1 mark for the key/table setup; 4 marks for the letter-by-letter working; 1 mark for the complete answer.

Confidence: computed - matches lecture slide 15 (standard tableau).

PART A - QUESTION 3

A3a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

List two characteristics of Trojan horses as a type of malware.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	They disguise themselves as useful or benign software.	"They usually masquerade as helpful or harmless programs"	051 - Software Security, slide 12 051 - Software Security::s12::1	supported	0.20 LOW
2	They may steal private data, delete files, log keystrokes, or open the system for further malware.	"begin to steal private data, delete files, log keystrokes or provide an opening for further malware to get installed"	051 - Software Security, slide 12 051 - Software Security::s12::1	supported (stem gate)	0.77

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 051 - Software Security, slide 12

A3b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

State six techniques by which malware attacks systems or propagates, including how a virus infects executable files and how a worm spreads.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	A virus can append its body to a host program and redirect the program's entry point to the virus code.	"Append a virus body to a program"	051 - Software Security, slide 9 051 - Software Security::s09::1	partly supported	0.40 LOW
2	After running, the virus restores the original entry point and transfers control back to it.	"Virus code restores the original entry point and jumps to it after its own execution"	051 - Software Security, slide 9 051 - Software Security::s09::1	supported (stem gate)	0.60
3	A virus can overwrite a program header so that execution begins at the virus instead of the original code.	"Over write a program header to switch the entry point to a virus"	051 - Software Security, slide 10 051 - Software Security::s10::1	supported	0.30 LOW
4	A worm can propagate by exploiting a remote execution feature of a network service such as sendmail.	"Used a debugging feature of sendmail (remote execution)"	051 - Software Security, slide 7 051 - Software Security::s07::1	supported	0.30 LOW
5	A rootkit hides malicious processes and software so the attacker keeps privileged remote access after a vulnerability is exploited.	"Rootkits are a type of malware that mask malicious processes and software in the infected systems to ensure privileged remote access."	051 - Software Security, slide 13 051 - Software Security::s13::1	supported (stem gate)	0.54
6	Spyware steals user credentials and records activity such as keystrokes and visited sites.	"They steal user logins and passwords, document sites visited, log keystrokes and even redirect browsers to unwanted sites."	051 - Software Security, slide 13 051 - Software Security::s13::1	supported (stem gate)	0.50

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited

lecture slide.
Citations: 051 - Software Security, slide 10; 051 - Software Security, slide 13; 051 - Software Security, slide 7; 051 - Software Security, slide 9

PART A - QUESTION 4

A4a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the Chinese Wall model's purpose and its two access rules.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	The Chinese Wall policy was proposed by Brewer and Nash to address conflicts of interest.	"Brewer and Nash (1989) proposed a policy called the Chinese Wall Policy that addresses such conflicts of interest."	024 - Formal Security Model, slide 21 024 - Formal Security Model:: s21::1	supported (stem gate)	1.00
2	The simple security rule allows access only to objects within the same company datasets already accessed or in an entirely different conflict of interest class.	"A subject s can be granted access to an object o only if the object: is in the same company datasets as the objects already accessed by s, that is, "within the Wall," or belongs to an entirely different conflict of interest class."	024 - Formal Security Model, slide 25 024 - Formal Security Model:: s25::1	supported (stem gate)	0.75

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 024 - Formal Security Model, slide 21; 024 - Formal Security Model, slide 25

Status: computed placeholder - no question generated for this type.

PART A - QUESTION 5

A5a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State the two stages of the biometric authentication process.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	The identification stage, which involves acquiring the biometric and creating and storing master characteristics.	"Identification Stage Acquisition Creation of Master characteristics Storage of Master characteristics"	072 - Biometrics and Authentication, slide 5 072 - Biometrics and Authentication:: s05::1	supported	0.38 LOW
2	The authentication stage, which involves further acquisition, comparison and a decision.	"Authentication Stage Acquisition(s) Comparison Decision"	072 - Biometrics and Authentication, slide 5 072 - Biometrics and Authentication:: s05::1	supported (stem gate)	0.71

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 072 - Biometrics and Authentication, slide 5

A5b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss six aspects of biometric mechanisms and technologies, covering their definition, categories, and the strengths and weaknesses of specific biometric methods.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	A biometric is defined as a physiological or behavioural characteristic that can distinguish one person from another and can be used for identification or verification.	"A biometric is a physiological or behavioural characteristic of a human being that can distinguish one person from another and that theoretically can be used for identification or verification of identity."	072 - Biometrics and Authentication, slide 2 072 - Biometrics and Authentication:: s02::1	supported (stem gate)	0.90
2	Biometric applications are categorized into two sectors: psychological and behavioural.	"Biometric applications available today are categorized into 2 sectors"	072 - Biometrics and Authentication, slide 4 072 - Biometrics and Authentication:: s04::1	supported (stem gate)	0.71
3	The psychological category includes iris, fingerprints, hand, retinal and face recognition.	"Psychological: Iris, Fingerprints, Hand, Retinal and Face recognition"	072 - Biometrics and Authentication, slide 4 072 - Biometrics and Authentication:: s04::1	supported (stem gate)	0.78
4	The behavioural category includes voice, typing pattern and signature.	"Behavioural: Voice, Typing pattern, Signature"	072 - Biometrics and Authentication, slide 4 072 - Biometrics and Authentication:: s04::1	supported (stem gate)	0.67
5	Retinal scanning is very efficient and cannot be spoofed, but has disadvantages such as high failure-to-enrol ratio, acceptability concerns, light exposure and hygiene.	"Very efficient - cant be spoofed!"	072 - Biometrics and Authentication, slide 9 072 - Biometrics and Authentication:: s09::1	partly supported	0.16 LOW
6	Fingerprint biometrics suffer from disadvantages including racial issues, dirt, grime and wounds, placement of finger, large database processing, and spoofing concerns.	"Racial issues"	072 - Biometrics and Authentication, slide 7 072 - Biometrics and Authentication:: s07::1	partly supported	0.12 LOW

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 072 - Biometrics and Authentication, slide 2; 072 - Biometrics and Authentication, slide 4; 072 - Biometrics and Authentication, slide 7; 072 - Biometrics and Authentication, slide 9

PART A - QUESTION 6

A6a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) differences between morals and laws.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	Morals are described as traditions of belief concerning right and wrong conduct.	"Morals are traditions of belief about right and wrong conduct"	071 - Ethics and Computer Security, slide 5 071 - Ethics and Computer Security::s05::1	supported (stem gate)	0.86
2	Laws are formal rules of conduct imposed by a sovereign authority such as a government.	"Laws are formal rules of conduct that a sovereign authority, such as a government, imposes on its subjects or citizens"	071 - Ethics and Computer Security, slide 5 071 - Ethics and Computer Security::s05::1	supported (stem gate)	1.00

© Hak Cipta Universiti Teknologi MARA

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 071 - Ethics and Computer Security, slide 5

A6b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain how a professional code of ethics guides computing professionals, referring to the ACM code and ACM professional conduct.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	A code of ethics is a documented set of acceptable behaviours for a professional group.	"Documented set of acceptable behaviors for professional or social groups."	071 - Ethics and Computer Security, slide 6 071 - Ethics and Computer Security::s06::1	supported (stem gate)	0.62
2	The code is defined by the professional group itself.	"Defined by the group."	071 - Ethics and Computer Security, slide 6 071 - Ethics and Computer Security::s06::1	supported	0.40 LOW
3	The code identifies which specific actions are appropriate or inappropriate.	"Identifies specific actions as appropriate or inappropriate."	071 - Ethics and Computer Security, slide 6 071 - Ethics and Computer Security::s06::1	supported (stem gate)	0.75
4	The ACM code requires professionals to contribute to society and human well-being, treating all people as stakeholders.	"Contribute to society and to human well-being, acknowledging that all people are stakeholders in computing."	071 - Ethics and Computer Security, slide 11 071 - Ethics and Computer Security::s11::1	supported (stem gate)	0.58
5	The ACM code requires professionals to respect privacy and honour confidentiality.	"Respect privacy."	071 - Ethics and Computer Security, slide 11 071 - Ethics and Computer Security::s11::1	partly supported	0.25 LOW
6	ACM professional conduct requires professionals to give comprehensive and thorough evaluations of computer systems and their impacts, including possible risks.	"Give comprehensive and thorough evaluations of computer systems and their impacts, including analysis of possible risks."	071 - Ethics and Computer Security, slide 12 071 - Ethics and Computer Security::s12::1	supported (stem gate)	0.69

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 071 - Ethics and Computer Security, slide 11; 071 - Ethics and Computer Security, slide 12; 071 - Ethics and Computer Security, slide 6

PART A - QUESTION 7

A7a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain how NIDS sensors should be positioned in a network and give two typical sensor locations.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap

© Hak Cipta Universiti Teknologi MARA

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	Sensors should be placed deliberately so that the organization's most valuable assets are protected.	"Place IDS sensors strategically to defend most valuable assets"	062 - Intrusion Detection System, slide 7 062 - Intrusion Detection System::s07::1	supported (stem gate)	0.56
2	One typical location is just inside the firewall.	"Just inside the firewall"	062 - Intrusion Detection System, slide 7 062 - Intrusion Detection System::s07::1	supported (stem gate)	0.60

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 062 - Intrusion Detection System, slide 7

A7b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Refer to your answer in (a). Explain six preventive network security mechanisms, other than the NIDS, that an organization can deploy to protect its network, and state what each mechanism does.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	A firewall controls incoming and outgoing network traffic according to predetermined security policies.	"Control incoming and outgoing traffic on network with predetermined security policies."	061 - Network Security, slide 3 061 - Network Security::s03::1	supported (stem gate)	0.80
2	A proxy server improves data security and network performance by acting as a firewall and web filter, providing shared connections and caching data.	"Proxy servers act as a firewall and web filter, provide shared network connections, and cache data to speed up common requests."	061 - Network Security, slide 3 061 - Network Security::s03::1	supported (stem gate)	0.80
3	Network segmentation creates boundaries between segments whose computing assets share a common function, risk or role.	"Boundaries between network segments where computing assets within the segment have a common function, risk or role within an organization."	061 - Network Security, slide 3 061 - Network Security::s03::1	supported (stem gate)	0.77
4	A remote access VPN gives individual hosts or clients secure remote access to the organization's network.	"Provides remote and secure access to an organization network to individual hosts or clients"	061 - Network Security, slide 4 061 - Network Security::s04::1	supported (stem gate)	0.89
5	Zero Trust Network Access limits each user to only the access and permissions needed for their role.	"A user should only has access and permission that required to fulfill the role"	061 - Network Security, slide 4 061 - Network Security::s04::1	supported (stem gate)	0.50
6	An intrusion detection/prevention system detects or prevents attacks such as brute force, denial-of-service and exploitation of network vulnerabilities.	"To detect or prevent the network security attacks such as brute force attacks, Denial-of-Service attacks and exploits of network vulnerabilities."	061 - Network Security, slide 4 061 - Network Security::s04::1	supported (stem gate)	0.85

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 061 - Network Security, slide 3; 061 - Network Security, slide 4

PART A - QUESTION 8

A8a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

List TWO (2) password security controls used to protect user accounts.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap

© Hak Cipta Universiti Teknologi MARA

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	Applying access control to the password files so they are protected.	"Access control applied to password files"	022 - Identification and Authentication, slide 12 022 - Identification and Authentication:: s12::1	supported (stem gate)	0.57
2	Deactivating accounts after several unsuccessful login attempts.	"De-activation of accounts after multiple failed logins"	022 - Identification and Authentication, slide 12 022 - Identification and Authentication:: s12::1	supported	0.43 LOW

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 022 - Identification and Authentication, slide 12

A8b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Describe six (6) aspects of Kerberos and single sign-on mechanisms, covering their motivation, design criteria, login procedure and alternatives.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	Single sign-on reduces the need for users to memorize passwords.	"Reduce the need to memorize passwords"	022 - Identification and Authentication, slide 16 022 - Identification and Authentication:: s16::1	supported (stem gate)	0.57
2	Single sign-on reduces the time spent typing passwords.	"Reduce the time spent on typing passwords"	022 - Identification and Authentication, slide 16 022 - Identification and Authentication:: s16::1	supported (stem gate)	0.67
3	Kerberos is designed to be secure against eavesdropping by never transmitting passwords in clear text.	"Security against eavesdropping: no password transmission in clear text."	022 - Identification and Authentication, slide 18 022 - Identification and Authentication:: s18::1	supported (stem gate)	0.60
4	Kerberos is designed for transparency, so the user is unaware of any authentication beyond the initial login.	"Transparency: user is not aware of any authentication beyond an initial login."	022 - Identification and Authentication, slide 18 022 - Identification and Authentication:: s18::1	supported (stem gate)	0.70
5	During Kerberos login, the hash of the user's password becomes the secret key of the client/user.	"The hash value of his password KU = h(P) becomes a secret key of the client/user."	022 - Identification and Authentication, slide 19 022 - Identification and Authentication:: s19::1	supported (stem gate)	0.67
6	Alternative authentication mechanisms to passwords include smart cards, biometric methods and two-factor authentication.	"Alternative user authentication mechanisms are smart cards, biometric methods and two-factor authentication."	022 - Identification and Authentication, slide 24 022 - Identification and Authentication:: s24::1	supported (stem gate)	0.80

© Hak Cipta Universiti Teknologi MARA

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 022 - Identification and Authentication, slide 16; 022 - Identification and Authentication, slide 18; 022 - Identification and Authentication, slide 19; 022 - Identification and Authentication, slide 24

PART A - QUESTION 9

A9a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain how the classes of threats affect confidentiality, integrity and availability.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	Disclosure threats such as snooping, sniffing and wiretapping breach confidentiality, which confidentiality services are meant to counter.	"Disclosure - unauthorized access to information"	011 - Introduction to Computer Security, slide 10 011 - Introduction to Computer Security::s10::1	partly supported	0.09 LOW
2	Deception threats such as modification and spoofing cause acceptance of false data, harming integrity, which integrity services counter.	"Deception - acceptance of false data"	011 - Introduction to Computer Security, slide 10 011 - Introduction to Computer Security::s10::1	partly supported	0.31 LOW

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 011 - Introduction to Computer Security, slide 10

A9b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

State six facts about the Samy worm and the XSS attack it used, covering how the script was injected, how it spread, and the outcome.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	The worm injected JavaScript into a user profile using document.body.innerHTML.	"Inject Javascript into a user profile using document.body.innerHTML"	052 - Web Security, slide 15 052 - Web Security::s15::1	supported (stem gate)	0.78
2	It obtained the list of the user's heroes by issuing a GET on a user profile.	"Get the list of user's heros by using a GET on a user profile"	052 - Web Security, slide 15 052 - Web Security::s15::1	supported (stem gate)	0.50
3	It added Samy as a friend field by performing XML-HTTP on the addFriends page.	"Add Samy as a field by performing XML-HTTP on the addFriends page"	052 - Web Security, slide 15 052 - Web Security::s15::1	supported (stem gate)	0.78
4	Any user visiting an infected user's page had their profile and friends list infected with the JavaScript.	"Any user who visits an infected user's page will gets profile infected with Javascript and his friends list infected with Samy"	052 - Web Security, slide 15 052 - Web Security::s15::1	supported (stem gate)	0.78
5	The infection eventually reached about 1,000,000 MySpace profiles.	"Eventually about 1,000,000 MySpace profiles were infected."	052 - Web Security, slide 15 052 - Web Security::s15::1	supported (stem gate)	0.71
6	The underlying XSS flaw is that any web application returning user input without filtering is a potential XSS vulnerability.	"Any web application that returns user input without filtering is a potential XSS vulnerability!"	052 - Web Security, slide 13 052 - Web Security::s13::1	supported (stem gate)	0.77

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 052 - Web Security, slide 13; 052 - Web Security, slide 15

© Hak Cipta Universiti Teknologi MARA

PART A - QUESTION 10

A10a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain two limitations of passive intrusion detection systems in defending against attacks.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	A passive detection system can only log and alert when an attack is identified, rather than acting on it.	"Can take passive action (logging and alerting) when an attack is identified"	062 - Intrusion Detection System, slide 29 062 - Intrusion Detection System::s29::1	supported (stem gate)	0.50
2	Such a system is unable to take active measures to halt an attack that is already underway.	"Cannot take active actions to stop an attack in progress"	062 - Intrusion Detection System, slide 29 062 - Intrusion Detection System::s29::1	supported	0.30 LOW

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 062 - Intrusion Detection System, slide 29

A10b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain six points about threat classes and the countermeasures used against attacks, covering how threats differ from vulnerabilities and attacks, how misuse detection counters known attacks, and how anomaly-based prediction counters unknown activity.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	A threat is only a potential violation of security, whereas an attack is the actual violation.	"Threats: A threat is a "potential" violation of security"	011 - Introduction to Computer Security, slide 9 011 - Introduction to Computer Security::s09::1	supported (stem gate)	0.50
2	An attack is defined as the actual violation of security, distinguishing it from a mere threat.	"Attacks: The actual violation of security"	011 - Introduction to Computer Security, slide 9 011 - Introduction to Computer Security::s09::1	supported (stem gate)	0.50
3	A vulnerability is a weakness of a system that can be exploited to damage assets.	"Vulnerabilities: Weakness of a system that can be exploited to damage assets"	011 - Introduction to Computer Security, slide 9 011 - Introduction to Computer Security::s09::1	supported (stem gate)	1.00
4	Misuse detection represents attacks as patterns or signatures so that variations of the same attack can be detected.	"there are ways to represent attacks in the form of a pattern or a signature so that even variations of the same attack can be detected"	062 - Intrusion Detection System, slide 17 062 - Intrusion Detection System::s17::1	supported (stem gate)	0.89
5	Misuse detection is effective against known attack patterns but of little use against unknown attack methods.	"They can detect many or all known attack patterns, but they are of little use for unknown attack methods."	062 - Intrusion Detection System, slide 17 062 - Intrusion Detection System::s17::1	supported (stem gate)	0.73

© Hak Cipta Universiti Teknologi MARA

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
6	Predictive pattern anomaly detection can flag anomalous activities that traditional methods found difficult to detect.	"Rule based sequential patterns can detect anomalous activities that were difficult with traditional methods."	062 - Intrusion Detection System, slide 25 062 - Intrusion Detection System::s25::1	supported (stem gate)	0.67

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 011 - Introduction to Computer Security, slide 9; 062 - Intrusion Detection System, slide 17; 062 - Intrusion Detection System, slide 25

PART B - QUESTION 1

B1a - 5 marks - supported by lecture slides (not lecturer-marked)

Scenario:

A consultant at a security firm must advise a client on how to represent and enforce access rights over shared documents and executables. The client wants a structure that is easy to verify, yet also wants to know the drawbacks of each representation before choosing one.

Question:

Explain the access control matrix, access control list and capability structures as ways of representing access rights, including one advantage and one disadvantage of each.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	The access control matrix is described as a basic control structure for implementing access policies.	"ACM is a basic control structure."	023 - Access Control and Authorization, slide 8 023 - Access Control and Authorization::s08::1	supported	0.43 LOW
2	The access control matrix offers clarity of definition and is easy to verify.	"Advantages: clarity of definition easy to verify"	023 - Access Control and Authorization, slide 8 023 - Access Control and Authorization::s08::1	supported	0.38 LOW
3	The access control matrix suffers from poor scalability and poor handling of changes.	"Disadvantages: poor scalability poor handling of changes"	023 - Access Control and Authorization, slide 8 023 - Access Control and Authorization::s08::1	supported (stem gate)	0.50
4	An access control list is an object-centred description of access rights, giving easy access to object access rights.	"ACL is an object-centered description of access rights:"	023 - Access Control and Authorization, slide 10 023 - Access Control and Authorization::s10::1	supported (stem gate)	0.57
5	Access control lists have the disadvantages of difficulty of revocation and difficulty of sharing.	"difficulty of revocation difficulty of sharing"	023 - Access Control and Authorization, slide 10 023 - Access Control and Authorization::s10::1	supported	0.29 LOW

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited

© Hak Cipta Universiti Teknologi MARA

lecture slide.
Citations: 023 - Access Control and Authorization, slide 10; 023 - Access Control and Authorization, slide 8

B1b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

State the four goals of access control that the consultant should consider when advising the client, and explain the role of a reference monitor in realizing the client's chosen access control policy.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	One goal of access control is to grant access to subjects.	"Goals of access control: Granting access"	023 - Access Control and Authorization, slide 4 023 - Access Control and Authorization::s04::1	supported (stem gate)	0.80
2	Another goal is to limit access.	"Limiting access"	023 - Access Control and Authorization, slide 4 023 - Access Control and Authorization::s04::1	supported (stem gate)	0.50
3	A further goal is to prevent access.	"Preventing access"	023 - Access Control and Authorization, slide 4 023 - Access Control and Authorization::s04::1	supported (stem gate)	0.50
4	The fourth goal is to revoke access that was previously granted.	"Revoking access"	023 - Access Control and Authorization, slide 4 023 - Access Control and Authorization::s04::1	partly supported	0.33 LOW
5	A reference monitor is the instrument through which access control policies are realized, and it can be deployed at all levels of the system hierarchy.	"Reference monitors are instruments for realization of access control policies. They can be deployed at all levels of system hierarchy."	023 - Access Control and Authorization, slide 18 023 - Access Control and Authorization::s18::1	supported (stem gate)	0.93

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 023 - Access Control and Authorization, slide 18; 023 - Access Control and Authorization, slide 4

PART B - QUESTION 2

B2a - 5 marks - supported by lecture slides (not lecturer-marked)

Scenario:

A hospital wants to prove to auditors that its servers boot only approved software. The vendor proposes a tamper-resistant chip on each motherboard that records what loads at startup, so that the final platform state can be checked against a known-good value.

Question:

Referring to the hospital proposal, explain how a TPM and a chain of trust together let the platform's boot state be verified as trusted.

Marking points:

© Hak Cipta Universiti Teknologi MARA

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	State that the TPM is a tamper-resistant hardware module mounted in the platform, which is why it can anchor trust.	"Trusted Platform Module (TPM): a tamper-resistant hardware module mounted in a platform."	073 - Trusted Computing, slide 6 073 - Trusted Computing::s06::1	supported (stem gate)	0.80
2	Identify the TPM's responsibilities as measurement, protected storage, integrity reporting and policy enforcement.	"Responsible for: measurement, (protected) storage, (integrity) reporting and policy enforcement."	073 - Trusted Computing, slide 6 073 - Trusted Computing::s06::1	supported (stem gate)	0.89
3	Explain that in the chain each stage measures and validates the following stage.	"Each stage measures and validates the next one"	073 - Trusted Computing, slide 8 073 - Trusted Computing::s08::1	supported (stem gate)	0.60
4	Note that the resulting measurements are recorded in Platform Configuration Registers on the TPM.	"Measurements go into Platform Configuration Registers (PCRs) on the TPM"	073 - Trusted Computing, slide 8 073 - Trusted Computing::s08::1	supported (stem gate)	0.62
5	Conclude that once the chain has run from the hardware TPM through the software stages, the whole platform is verified to be in a trusted state.	"At the end, the entire platform is verified to be in a trusted state"	073 - Trusted Computing, slide 8 073 - Trusted Computing::s08::1	supported	0.21 LOW

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 073 - Trusted Computing, slide 6; 073 - Trusted Computing, slide 8

B2b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss the NGSCB/Nexus components that the vendor in the scenario could use to isolate the hospital's trusted software from the ordinary operating system, and explain how each component contributes to that isolation.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Verdict	Overlap
1	Nexus is described as a special kernel forming the core of the trusted operating environment.	"Special kernel (core of the trusted operating)"	073 - Trusted Computing, slide 13 073 - Trusted Computing::s13::1	supported (stem gate)	0.62
2	The stated goal of the design is to keep normal-mode and trusted-mode processes isolated from each other in memory.	"Goal: Isolate the process of normal mode and trusted mode differently in memory"	073 - Trusted Computing, slide 13 073 - Trusted Computing::s13::1	supported (stem gate)	0.70
3	Nexus is a security kernel that is authenticated at boot time.	"Security kernel, authenticated on boot"	073 - Trusted Computing, slide 14 073 - Trusted Computing::s14::1	supported (stem gate)	0.67
4	Nexus provides the application interface to the TPM and does not trust the operating system.	"Application interface to TPM"	073 - Trusted Computing, slide 14 073 - Trusted Computing::s14::1	partly supported	0.30 LOW
5	The Nexus Computing Agent is a trusted software component that runs in trusted mode and communicates with Nexus.	"Runs in trusted mode that communicates with Nexus"	073 - Trusted Computing, slide 15 073 - Trusted Computing::s15::1	supported (stem gate)	0.62

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 073 - Trusted Computing, slide 13; 073 - Trusted Computing, slide 14; 073 - Trusted Computing, slide 15

End of marking scheme.

© Hak Cipta Universiti Teknologi MARA